

02 — Secure Networking (20–25%)

Official subsections:

- 1. Plan and implement security for virtual networks
 - 2. Plan and implement security for **private** access to Azure resources
 - 3. Plan and implement security for **public** access to Azure resources
-

1. NSG and ASG

Network Security Group

- **Stateful**, operates at **L3/L4** on a **5-tuple** (source, source port, destination, destination port, protocol).
- Attach to a **subnet**, a **NIC**, or both. Traffic is evaluated **subnet-then-NIC on inbound** and **NIC-then-subnet on outbound**.
- Rules have **priority 100–4096**; lower number = evaluated first; **first match wins** and evaluation stops.
- Actions are **Allow** or **Deny** only. There is no logging action on an NSG rule itself.

Default rules (cannot be deleted, can be overridden by lower-priority-number rules):

Direction	Priority	Rule	Action
Inbound	65000	AllowVnetInBound	Allow
Inbound	65001	AllowAzureLoadBalancerInBound	Allow

Inbound	65500	DenyAllInBound	Deny
Outbound	65000	AllowVnetOutBound	Allow
Outbound	65001	AllowInternetOutBound	Allow
Outbound	65500	DenyAllOutBound	Deny

Key consequences: **VNet-to-VNet traffic is allowed by default** (including across peering), **inbound internet is denied by default**, and **outbound internet is allowed by default**.

- **Service tags** — Microsoft-managed IP groups used as source/destination: `Internet`, `VirtualNetwork`, `AzureLoadBalancer`, `Storage`, `Sql`, `AzureActiveDirectory`, `AzureCloud`, `AzureKeyVault`, and regional variants (`Storage.WestEurope`). They remove the need to maintain IP lists.
- **Effective security rules** (on the NIC) — the tool for troubleshooting *"why is this blocked"*. Combines subnet and NIC NSGs.
- **NSG flow logs** → storage account, then **Traffic Analytics** (via Log Analytics) for visualisation. Note: NSG flow logs are on a **retirement path in favour of VNet flow logs** — for the exam, know both exist and that VNet flow logs are the newer, VNet-scoped successor.

Application Security Group

- A logical **grouping of NICs**; used as **source or destination in NSG rules** instead of IP addresses.
- All NICs in an ASG must be in the **same VNet**. If a rule references ASGs on both sides, both must be in the same VNet.
- Purpose: express intent — *"allow WebASG → AppASG on 443"* — with no IP maintenance as VMs scale.

2. Azure Virtual Network Manager (AVNM) —

on the outline, often missed

Centrally group, configure, and deploy network config **across subscriptions, regions, and tenants**.

Four-stage workflow: define the **scope** (subscriptions or management groups) → create **network groups** (manual membership or **dynamic via Azure Policy**) → create **configurations** → **deploy to regions**.
Configurations do nothing until deployed to a region.

Three configuration types:

Type	Does
Connectivity	Build mesh or hub-and-spoke topologies at scale, including direct spoke-to-spoke connectivity without manual peerings
Security admin	Security admin rules — global rules evaluated before NSGs
Routing	Orchestrate UDRs at scale

Security admin rules are the exam-critical bit: they are evaluated **before NSG rules**, and an `Always Allow` or `Deny` security admin rule **cannot be overridden by a resource owner's NSG**. Actions are **Allow**, **Deny**, and **Always Allow**.

- `Deny` → traffic blocked; NSG never evaluated.
- `Allow` → traffic then falls through to NSG evaluation (NSG can still deny it).
- `Always Allow` → traffic permitted and NSG evaluation is skipped for that flow.

Exam pattern: "Central security team must guarantee that RDP from the internet is blocked on every VNet, and application teams must not be able to override it." → **AVNM security admin rule with Deny**, not an NSG.

3. Azure Firewall

Managed, **stateful**, cloud-native **network firewall** with built-in HA and unrestricted scale. Requires a dedicated subnet named **AzureFirewallSubnet**, minimum /26. (Forced tunnelling adds AzureFirewallManagementSubnet, also /26.)

Rule types and processing order

NAT rules → **Network rules** → **Application rules**. Within each collection group, priority order applies. **Network rules are always processed before application rules**, and rule processing terminates on a match.

Rule type	Matches on	Use for
DNAT	Destination IP:port	Inbound publishing — translate firewall public IP to a private IP
Network	Source, destination (IP/ service tag/FQDN), port, protocol (TCP/UDP/ICMP/ Any)	L3/L4 filtering, non-HTTP protocols
Application	Source, FQDN , protocol:port, FQDN tags, web categories	Outbound HTTP/HTTPS/MSSQL filtering by name

- **FQDN tags** — pre-defined groups of FQDNs for well-known services (WindowsUpdate, AzureBackup, AzureKubernetesService). Usable **only in application rules**.
- **Threat intelligence-based filtering** — modes **Off / Alert only / Alert and deny**. Blocks traffic to/from known-malicious IPs and domains from the Microsoft threat intel feed. **Alert only is the default when enabled**.
- **Explicit deny is implicit**: anything not matched by an allow rule is denied.

SKUs

	Basic	Standard	Premium
Throughput	Up to 250 Mbps	Up to 30 Gbps	Up to 100 Gbps
L3–L7 filtering, threat intel	Alert only (fixed)	Alert / Alert and deny	Alert / Alert and deny
TLS inspection	–	–	✓
IDPS (signature-based, ~67k signatures)	–	–	✓
URL filtering (full URL, not just FQDN)	–	–	✓
Web categories	–	Coarse (application rules)	Granular, with category exceptions
Target	SMB, <250 Mbps	Most enterprises	Highly sensitive / regulated

Premium TLS inspection requires an **intermediate CA certificate** stored in **Key Vault**, accessed via a **user-assigned managed identity**.

Azure Firewall Manager

Central management for **firewall policies** across many firewalls.
Manages two architectures:

- **Secured virtual hub** — an Azure **Virtual WAN** hub with Azure Firewall (or a supported third-party SECaaS) deployed into it. Microsoft manages the routing.
- **Hub virtual network** — a standard VNet you manage, with your own UDRs.

Firewall Manager also centralises **DDoS protection plans**, **WAF policies**, and **Firewall Policy** hierarchies (a child policy **inherits** from a parent policy; child rules cannot remove parent rules).

Firewall Policy vs classic rules: policies are the modern, reusable, hierarchical object and are required for Premium features. Classic rule collections are legacy.

4. Application Gateway and WAF

Application Gateway

- **Layer 7** load balancer, **regional**.
- Features: TLS/SSL **termination** and **end-to-end TLS**, cookie-based **session affinity**, **URL path-based routing**, **multi-site hosting**, redirection, custom health probes, **autoscaling** (v2), rewrite HTTP headers and URL, **mutual TLS (mTLS)** client authentication (v2), **Private Link** support.
- Needs its own subnet; cannot share with other resources.

Web Application Firewall (WAF)

Protects against **OWASP Top 10** — SQL injection, cross-site scripting, command injection, HTTP protocol violations, bots.

Where WAF runs	Scope	Use when
Application Gateway	Regional, per-VNet	Regional web app, backend in a VNet
Azure Front Door	Global, at the edge	Global app, want attacks stopped before they reach the region
Azure CDN	Edge, static content	CDN endpoints

- **Modes: Detection** (log only) and **Prevention** (log and block). Always start in Detection, review logs, then switch.
- **Managed rule sets** — OWASP **Core Rule Set (CRS)** 3.2 / 3.1 / 3.0, and the newer **DRS (Default Rule Set)** on Front Door, plus the **Bot Manager** ruleset (Bad / Good / Unknown bots).
- **Custom rules** are evaluated **before** managed rules, by **priority** (lower first). Match on IP, geo-location, size, string, and can **Allow** / **Block** / **Log**, plus **rate limiting** (Front Door and App Gateway v2).
- **Exclusions** — the correct fix for a **false positive**: exclude a specific request header, cookie, query-string arg, or body attribute from evaluation. Disabling the whole rule is the wrong answer if a narrower exclusion exists.
- **WAF policies** are attached at **global**, **per-site (listener)**, or **per-URI (path)** level on App Gateway.
- **Logs**: `ApplicationGatewayFirewallLog`, `ApplicationGatewayAccessLog` → Log Analytics.

Azure Front Door (including CDN)

Global L7 entry point: anycast, split TCP, **edge WAF**, TLS offload, caching (**Azure Front Door Standard/Premium** absorbed the classic CDN offering), **Private Link origins** (Premium), rules engine, and always-on Layer 3/4 **DDoS protection** at the edge. Origin can be locked down to accept only Front Door traffic using the **AzureFrontDoor.Backend service tag** plus the **X-Azure-FDID** header check.

5. Private Endpoint vs Service Endpoint — the highest-yield distinction in the domain

	Private Endpoint (Azure Private Link)	Service Endpoint

What it is	A NIC with a private IP from your subnet, mapped to one specific PaaS resource instance	A route optimisation that extends VNet identity to the service over the Azure backbone
Source IP the service sees	The endpoint's private IP	The VNet's private IP
Destination IP	Private IP in your address space	The service's public IP (traffic stays on the Azure backbone)
Granularity	Per resource instance (this storage account, even this sub-resource: blob/file/table)	Per service type across the whole subnet (Microsoft.Storage for all storage)
Reachable from on-premises (VPN/ExpressRoute)	✓ Yes	✗ No
Reachable from peered VNets	✓ Yes	✗ No (endpoint applies only to its own subnet)
Works cross-region	✓ Yes	Only with the regional service
DNS changes needed	✓ Yes — a privatelink.* Private DNS zone	✗ No
Cost	Charged (per endpoint-hour + data)	Free
Data exfiltration control	Strong — plus you can disable public access entirely	Weaker; use Service Endpoint Policies to restrict which storage accounts are reachable

Underlying tech	Private Link	VNet service endpoint
-----------------	--------------	-----------------------

DNS is the number-one Private Endpoint exam trap. Without a Private DNS zone, `mystorage.blob.core.windows.net` still resolves to the **public** IP and traffic does not use the endpoint. The chain is:

`mystorage.blob.core.windows.net` → CNAME → `mystorage.privatelink.blob.core.windows.net` → **A record in the `privatelink.blob.core.windows.net` private DNS zone** → private IP.

Common zone names: `privatelink.blob.core.windows.net`, `privatelink.file.core.windows.net`, `privatelink.vaultcore.azure.net` (Key Vault), `privatelink.database.windows.net` (Azure SQL), `privatelink.azurecr.io` (ACR), `privatelink.azurewebsites.net` (App Service).

For on-premises resolution: use a **DNS forwarder / Azure DNS Private Resolver** in the VNet, with on-prem conditional forwarders pointing at it.

Private Link Service

The provider-side object: publish **your own service** (behind a **Standard Internal Load Balancer**) so consumers in other VNets or tenants can reach it via **their** private endpoints. Approval workflow: auto-approve list, or manual approval of connection requests.

Decision shortcut:

- Must be reachable **from on-premises** → Private Endpoint.
- Must **remove the public endpoint entirely** → Private Endpoint (+ `publicNetworkAccess = Disabled`).
- **Cost is the constraint**, only Azure VMs need access, whole-subnet granularity is fine → Service Endpoint.

6. Network integration for App Service, Functions, and ASE

Direction	Feature	Notes
Inbound to the app	Private Endpoint	Removes public access; app reachable only from the VNet
Inbound filtering	Access restrictions	IP/CIDR allow-deny rules, service tags, and rules for the SCM/Kudu site separately
Outbound from the app	VNet integration (regional)	App reaches resources in the VNet; requires a delegated subnet (<code>Microsoft.Web/serverFarms</code>)
Both, isolated	App Service Environment (ASE) v3	Single-tenant deployment into your VNet . Internal (ILB) or external VIP. NSGs and UDRs apply to the ASE subnet.

Other App Service security: **managed identity**, **Key Vault references** (`@Microsoft.KeyVault(SecretUri=...)`) so secrets never sit in app settings, **HTTPS Only**, **minimum TLS version**, client certificates (**mTLS**), and **Easy Auth** (App Service Authentication).

Azure SQL Managed Instance networking

- Deploys into a **dedicated, delegated subnet** in your VNet (`Microsoft.Sql/managedInstances`). No other resources in that subnet.
- Requires a **route table** and an **NSG** on the subnet with specific mandatory inbound/outbound rules for the management endpoint.
- Access is via a **private IP** by default; a **public endpoint** can be optionally enabled (port **3342**) — disabling it is the hardening answer.

API Management

- Modes: **External** (VNet, public VIP), **Internal** (VNet, private VIP only), or **none**. v2 tiers support **private endpoints** and **VNet injection**.
 - Security controls: **subscription keys**, **OAuth 2.0 / JWT validation policy** (`validate-jwt`), **client certificates (mTLS)**, **rate-limit** and **quota** policies, IP filter policy, **managed identity** to reach backends, and **minimum TLS version** / cipher configuration.
-

7. VNet peering, VPN, and ExpressRoute

VNet peering

- **Non-transitive.** $A \leftrightarrow B$ and $B \leftrightarrow C$ does **not** give $A \leftrightarrow C$. Solve with a **hub NVA/Firewall + UDRs**, a **full mesh**, or **AVNM connectivity configuration**.
- Address spaces **must not overlap**.
- **Global VNet peering** works across regions.
- Options: *Allow forwarded traffic*, *Allow gateway transit* (hub shares its VPN/ER gateway), *Use remote gateways* (spoke consumes it). Gateway transit and use-remote-gateways are set on **opposite** sides.
- Peering traffic **stays on the Microsoft backbone** — no public internet, no encryption required by default.

VPN Gateway

- Requires a subnet named **GatewaySubnet**, minimum **/29**, **/27 or larger recommended**.
- Types: **Site-to-Site (S2S)** — IPsec/IKE, needs a **Local Network Gateway** representing on-prem; **VNet-to-VNet**; **Point-to-Site (P2S)** — individual client devices.

- Route-based vs policy-based: **route-based** for almost everything (multiple tunnels, P2S coexistence); policy-based is legacy, single tunnel, IKEv1.
- **Active-active** for redundancy; **BGP** for dynamic routing.

Point-to-Site protocols and authentication:

Protocol	Auth supported	Notes
OpenVPN (SSL/TLS 443)	Microsoft Entra ID , certificate, RADIUS	Only OpenVPN supports Entra ID authentication — memorise this
SSTP (TLS 443)	Certificate, RADIUS	Windows only , firewall-friendly
IKEv2 (IPsec)	Certificate, RADIUS	Cross-platform

Certificate auth for P2S: upload the **root certificate public key** to the gateway; issue **client certificates** from that root. Revoke a client by adding its **thumbprint** to the gateway's revocation list.

Custom IPsec/IKE policy on a connection lets you enforce specific encryption (AES256), integrity (SHA256), DH group, and PFS — the answer to "the connection must use AES-256".

Encryption over ExpressRoute

By default, **ExpressRoute traffic is NOT encrypted**. It is private, but not encrypted.

	MACsec	IPsec
Layer	Layer 2 (MAC)	Layer 3 (IP)
Scope	Point-to-point — the physical links between your routers and Microsoft's	End-to-end — your on-prem network to your VNet

Requires	ExpressRoute Direct only — not available on provider-provisioned circuits	Any ExpressRoute circuit, via VPN Gateway over private peering
Key management	Bring your own key, stored in Azure Key Vault ; you control rotation	Standard IPsec/IKE
Ciphers	GCM-AES-128/256, GCM-AES-256/256	Standard IPsec suites
Granularity	All-or-nothing on the port — encrypts BGP control traffic too	Per tunnel

They can be enabled **independently or together**. ExpressRoute is a **trusted Microsoft service** for Key Vault firewall purposes, so the MACsec key vault can keep its firewall on.

Exam pattern: "Encrypt traffic over an ExpressRoute circuit provisioned by a connectivity provider." → **IPsec via VPN Gateway over private peering** (MACsec is not possible — it needs ExpressRoute Direct).

8. UDRs and forced tunnelling

- A **route table** attached to a subnet overrides Azure's default system routes.
- **Next hop types:** `VirtualAppliance` (specify the NVA/Firewall private IP), `VirtualNetworkGateway`, `VirtualNetwork`, `Internet`, `None` (blackhole).
- **Route selection precedence:** **User-defined route** → **BGP route** → **System route**. Within that, **longest prefix match** wins.
- **Forced tunnelling** = `0.0.0.0/0` → next hop the Azure Firewall or on-prem gateway, so all internet-bound traffic is inspected. Standard hub-and-spoke pattern.
- `0.0.0.0/0` → `None` blackholes all internet traffic from the

subnet.

- **Do not put a 0.0.0.0/0 UDR on AzureFirewallSubnet** pointing back at the firewall — it creates a loop. GatewaySubnet also has restrictions.

9. DDoS Protection

Azure has **always-on, free, platform-level** DDoS infrastructure protection. The paid tiers add tuning and support:

	DDoS Network Protection	DDoS IP Protection
Scope	A DDoS plan attached to VNets — covers all public IPs in them	A single public IP address
Pricing	Fixed monthly per plan (covers 100 public IPs) + overage	Per protected IP , no fixed fee
Adaptive tuning	✓	✓
Attack analytics, metrics, mitigation reports and flow logs	✓	✓
Rapid Response (DRR) support team	✓	✗
Cost protection (service credits)	✓	✗
WAF discount	✓	✗
Best for	Enterprises with many public IPs	SMB or a single exposed workload

Protects against **L3/L4** volumetric, protocol, and resource-exhaustion

attacks. **Application-layer (L7) attacks need WAF** — pair DDoS Protection with WAF for full coverage. Only **public IP addresses** are protected.

10. Network Watcher — the monitoring toolset

Tool	Answers
IP flow verify	"Is this specific 5-tuple allowed or denied, and by which NSG rule ?"
NSG diagnostics	Newer, richer version of IP flow verify — evaluates all applicable NSGs
Next hop	"Where does traffic to this destination actually go?" — diagnoses UDR problems
Effective security rules	Combined view of all NSG rules on a NIC
Connection troubleshoot	One-off reachability test with latency and hop detail
Connection monitor	Continuous connectivity monitoring with alerts
VPN troubleshoot	Diagnose gateway and connection problems
Packet capture	Capture traffic on a VM (requires the Network Watcher agent extension)
Topology	Visualise the VNet
Flow logs (NSG / VNet)	Record allowed and denied flows → Traffic Analytics

Exam shortcut: "Which NSG rule is blocking this?" → **IP flow verify**. "Why is traffic not reaching the firewall?" → **Next hop**. "Continuously alert if connectivity breaks" → **Connection monitor**.

11. Firewall settings on Azure PaaS resources

Nearly every PaaS service has the same three-layer pattern. Learn it once, apply everywhere:

1. **Public network access:** Enabled from all networks / Enabled from selected networks and IPs / **Disabled**.
2. **Selected networks:** firewall **IP rules** + **VNet rules** (which require a **service endpoint** on the subnet).
3. **Private endpoint connections** — and a **"Allow trusted Microsoft services to bypass this firewall"** exception.

"Allow trusted Microsoft services" is the classic answer when a legitimate Azure service (Backup, Defender, Event Grid, ExpressRoute for MACsec keys) is being blocked by the firewall. Note that with Key Vault's **Network Security Perimeter** (`publicNetworkAccess: SecuredByPerimeter`), the trusted-services bypass is **overridden**.

Network Security Perimeter (NSP) — newer construct: a logical isolation boundary for **PaaS** resources (Key Vault, Storage, SQL) that sit outside a VNet, with inbound/outbound access rules and logging. Worth recognising by name.

Rapid-fire self-test

1. Default NSG behaviour for inbound internet / outbound internet? → **Deny / Allow**
2. Minimum subnet size for `AzureFirewallSubnet`, `GatewaySubnet`, `AzureBastionSubnet`? → **/26, /29 (use /27), /26**
3. Azure Firewall rule processing order? → **DNAT** → **Network** → **Application**
4. Which P2S protocol supports Entra ID auth? → **OpenVPN only**

5. Which encryption over ExpressRoute requires ExpressRoute Direct? → **MACsec**
6. Private Endpoint reachable from on-prem? Service Endpoint? → **Yes / No**
7. What breaks a Private Endpoint most often? → **Missing `privatelink.*` Private DNS zone**
8. Is VNet peering transitive? → **No**
9. Route precedence? → **UDR** → **BGP** → **System**
10. Which DDoS tier includes Rapid Response and cost protection? → **Network Protection**
11. Which rules are evaluated before NSGs and cannot be overridden? → **AVNM security admin rules**
12. Correct fix for a WAF false positive? → **An exclusion**, not disabling the rule